

Key Management and Distribution part II

MODULE V

X.509 Certificate fields cntd..

- A certificate has the following fields:
 - **Version number:** This field defines the version of X.509 of the certificate. The version number started at 0; the current version is 3.
 - **Serial number:** This field defines a number assigned to each certificate. The value is unique for each certificate issuer.
 - **Signature algorithm ID:** This field identifies the algorithm used to sign the certificate. Any parameter that is needed for the signature is also defined in this field.
 - **Issuer Name:** This field identifies the certification authority that issued the certificate. The name is normally a hierarchy of strings that defines a country, a state, organization, department, and so on.
 - **Validity period:** This field defines the earliest time (not before) and the latest time (not after) the certificate is valid.
 - **Subject name:** The field defines the entity to which the public key belongs. It is also a hierarchy of strings. Part of the field defines what is called the common name, which is the actual name of the beholder of the key.
 - **Subject public key:** The field defines the owners public key, the heart of the certificate. The field also defines the corresponding public key algorithm (RSA, for example) and its parameters.
 - **Issuer unique identifier:** The optional field allows two issuers to have the same issuer field value, if the *issuer unique identifiers* are different
 - **Subject unique identifier:** This optional field allows two different subjects to have the same subject field value if the subject unique identifiers are different.
 - **Extensions:** The optional field allows issuers to add more private information to the certificate.
 - **Signature:** This field is made of three sections. The first section contains all other fields in the certificate. The second section contains the digest of the first section encrypted with the CA's public key. The third section contains the algorithm identifier used to create the second section.

Certificate renewal

- Each certificate has a period of validity. If there is no problem with the certificate, the CA issues a new certificate before the old one expires. The process is like the renewal of credit cards by a credit card company.

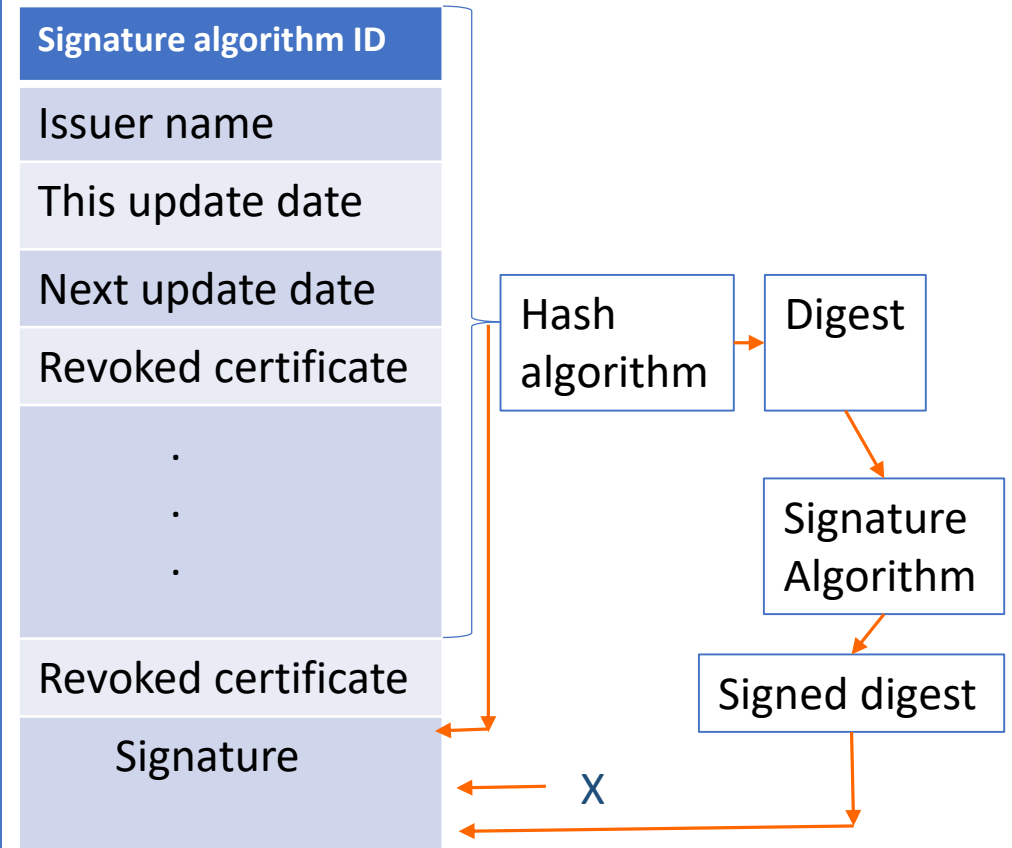
Certificate revocation

- In some cases a certificate must be revoked before its expiration. Here are some examples:
 - The user's (subject's) private key (corresponding to the public key listed in the certificate).
 - The CA is no longer willing to certify the user. For example, the user's certificate relates to an organization that she no longer works for.
 - The CA's private key, which can verify certificates, may have been compromised. In this case, the CA needs to revoke all unexpired certificates.
- The revocation is done by periodically issuing a certificate revocation list (CRL). The list contains all revoked certificates that are not expired on the date the CRL is issued. When a user wants to use a certificate, she first needs to check the directory of the corresponding CA for the last certificate revocation list.

Certificate revocation cntd..

A certificate revocation list has the following fields:

- **Signature algorithm ID:** This field is the same as the one in the certificate.
- **Issuer name:** This field is the same as the one in the certificate.
- **This update date:** This field defines when the list is released.
- **Next update date:** This field defines the next date when the new list will be released.
- **Revoked certificate:** This is a repeated list of all unexpired certificates that have been revoked. Each list contains two sections: user certificate serial number and revocation date.
- **Signature:** This field is the same as the one in the certificate list.



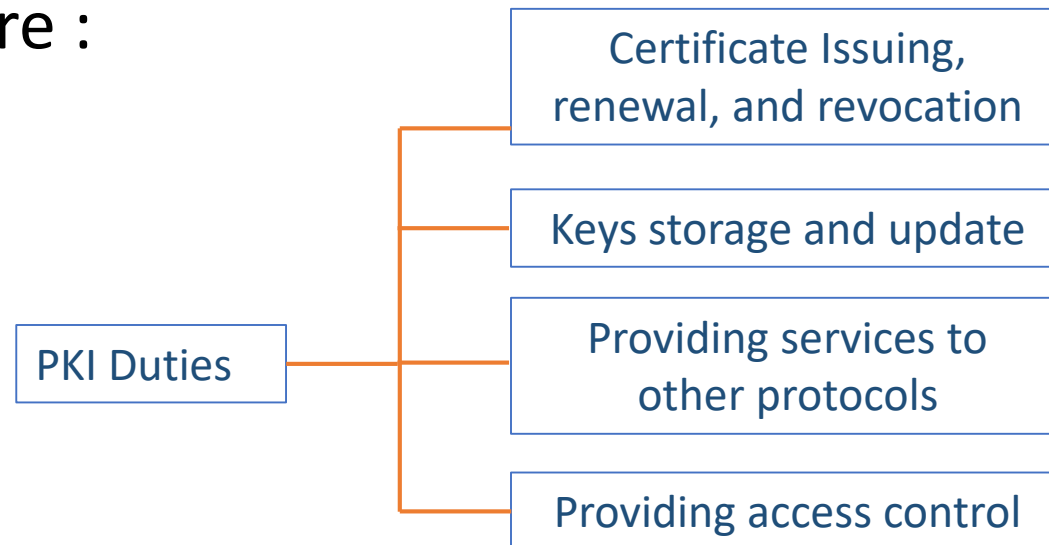
$X = \text{Hash algorithm ID} + \text{cipher ID} + \text{Parameters}$

Delta revocation

- To make revocation more efficient, the delta certificate revocation list (delta CRL) has been introduced. A delta CRL is created and posted on the directory if there are changes after *this update date* and *next update date*. For example, if CRLs are issued every month,, but there are revocations in between, the CA can create a delta CRL when there is a change during the month. However, a delta CRL contains only the changes made after the last CRL.

Public Key Infrastructure (PKI)

- PKI model is a model for creating, distributing, and revoking certificates based on the X.509. The Internet Engineering Task Force has created the public key Infrastructure X.509 (PKIX).
- Duties: Several duties have been defined for a PKI. The most important ones are :



Public Key Infrastructure (PKI) cntd..

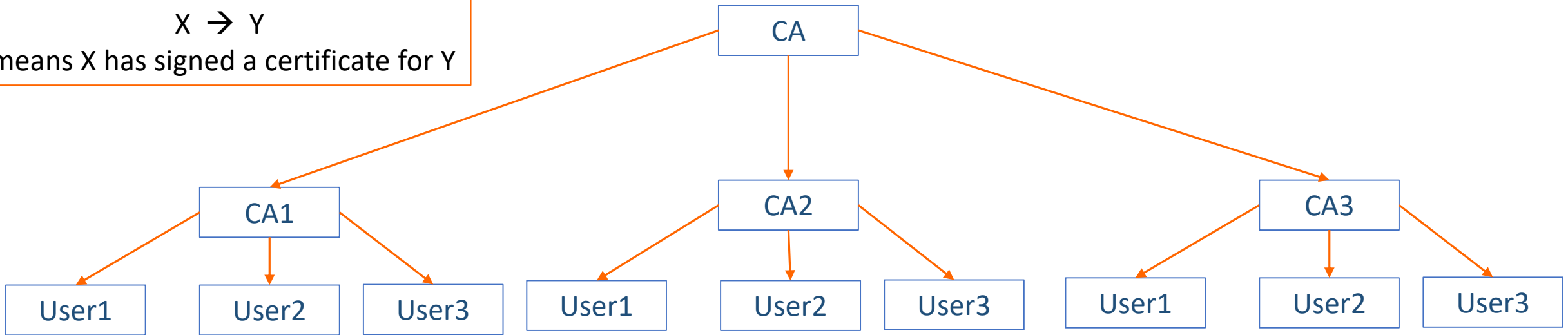
- **Certificate's Issuing, renewal, and revocation:** These are duties in the X.509. Because the PKIX is based on X.509, it needs to handle all duties related to certificates.
- **Key's storage and update:** A PKI should be a storage place for private keys of those members that need to hold their private keys somewhere safe. In addition, a PKI is responsible for updating these keys on members demands.
- **Providing services to other protocols:** Some Internet security protocols, such as IPsec and TLS, are relying on the services by a PKI.
- **Providing access control:** A PKI can provide different levels of access to the Information stored in its database. For example, an organization PKI may provide access to the whole database for the top management, but limited access for employees.

Trust Model

- It is not possible to have just one CA issuing all certificates for all users in the world. There should be many CAs, each responsible for creating, storing, issuing, and revoking a limited number of certificates. The trust model defines rules that specify how a user can verify a certificate received from a CA.
- Hierarchical Model: In this model, there is a tree-type structure with a root CA. The root CA has a self-signed, self-issued certificate; it needs to be trusted by other CAs and users for the system to work. The below figure shows a trust model of this kind with three hierarchical levels. The number of levels can be more than three in a real situation.

$X \rightarrow Y$

means X has signed a certificate for Y

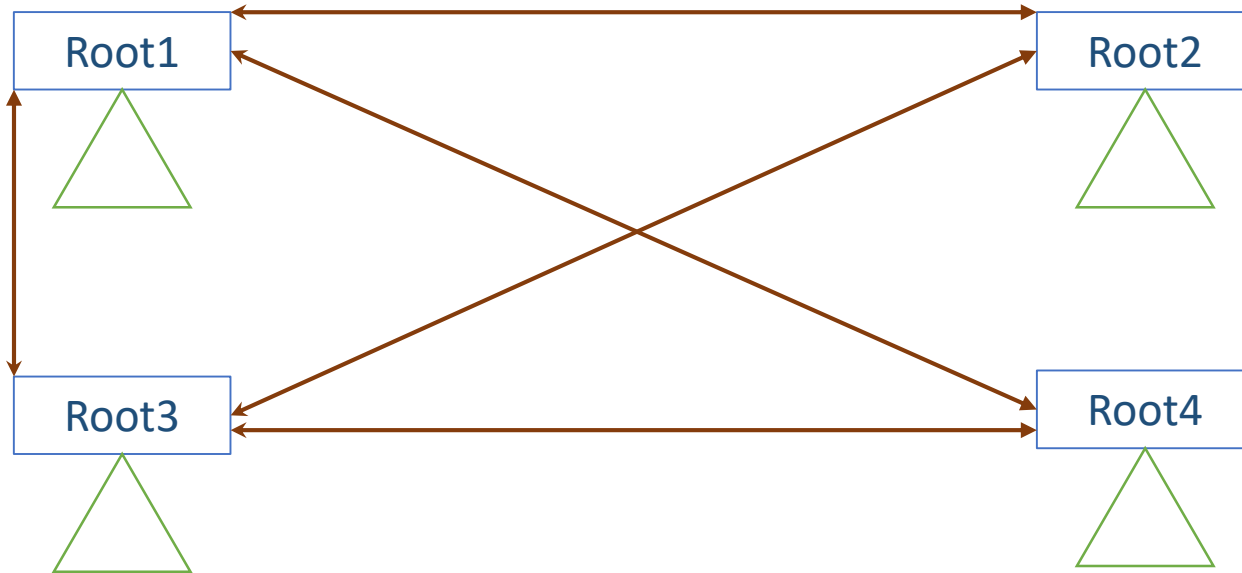


- The figure shows that the CA (the root) has signed certificates for CA1, CA2 and CA3; CA1 has signed certificates for User1, User2 and User3; and so on. PKI uses the following notation to mean the certificate issued by authority X for entity Y.

$X \ll Y \gg$

Mesh Model

- The hierarchical model may work for an organization or a small community. A larger community may need several hierarchical structures connected. One method is to use a mesh model to connect the roots together. In this model, each root is connected to every other root, as shown in the Figure. It shows that the mesh structure connects only roots together; each root has its own hierarchical structure, shown by a triangle. The certifications between the roots are cross-certificates; each root certifies all other roots, which means there are $N(N-1)$ certificates. There are 4 nodes, so we need $4*3 = 12$ certificates. Each double-arrow line represents two certificates.



$X \longleftrightarrow Y$
means X and Y has signed a certificate
for each other.